ENTREGA 6 — MVP Backend II e integración

Reglas de negocio, seguridad y comunicación entre servicios

Proyecto: PrestaLab

Materia: Arquitectura Orientada a Servicios

Docente: Ing. Luis Leonardo Mendoza Reséndiz

Equipo: Tranquilo nos la navegamos

Integrantes: Jhonatan Uriel Morales Badillo, José Vidal López Salazar, David Sosa Gómez, Alejandro Ramírez Contreras

Repositorio: https://github.com/JhonaRaida/prestalab

Tag / commit de la entrega: entrega-6 / _____

1. Reporte de la semana

Objetivo de la semana

Pasar de los CRUD básicos a un backend con autenticación, roles, reglas de negocio y un flujo completo que conecta varios servicios.

Qué se implementó

- Los seis componentes de la arquitectura: API Gateway y los servicios de Usuarios y Autenticación, Inventario, Reservas y Préstamos, Notificaciones y Reportes.
- Autenticación con JWT (1 hora de vigencia) y contraseñas con bcrypt. El Gateway valida el token y reenvía la identidad y el rol a cada servicio.
- Cuatro roles: administrador, encargado, docente y alumno, con permisos distintos por endpoint.
- Validaciones de negocio (traslape de horarios, límite de reservas por rol, tolerancia, sanciones, cancelación).
- Operación entre servicios: la devolución de un equipo actualiza Reservas, crea incidencias, pone el recurso en mantenimiento (Inventario) y genera la sanción (Usuarios) dentro de una sola operación transaccional.
- Manejo consistente de errores (400, 401, 403, 404, 409, 422, 429, 503) con un formato estándar.
- Paginación y filtros en los listados, y colección Postman actualizada con casos positivos y negativos.

Qué cambió respecto a la entrega anterior

Se agregaron los recursos restantes (reservas, préstamos, incidencias, sanciones, notificaciones y reportes), la seguridad por roles y la lógica de negocio. Los cambios menores al contrato de la API quedaron sincronizados en docs/openapi.yaml: campos tipo y encargadoId en Recurso, dos rutas internas de solo lectura para Reportes, dos códigos 422 nuevos (LABORATORIO_NO_VALIDO y CATEGORIA_NO_VALIDA) y las fechas en UTC.

Problemas encontrados y cómo se resolvieron

Problema	Solución
Dos usuarios podían reservar el mismo recurso al mismo tiempo	Restricción EXCLUDE con gist en la tabla de reservas: la base rechaza la segunda y la API responde 409 RESERVA_TRASLAPADA.
El límite de reservas por usuario se podía saltar con peticiones simultáneas	pg_advisory_xact_lock dentro de la transacción de creación.
Una devolución podía quedar a medias si otro servicio fallaba	Si Inventario o Usuarios no responden se revierte todo y se responde 503; se puede reintentar.
Una caída de Notificaciones no debía frenar las reservas	El aviso es no bloqueante: la reserva se crea igual y solo se registra una advertencia.
Alguien podía saltarse el Gateway o falsear su rol	Los servicios exigen el X-Service-Token interno y el Gateway ignora cualquier cabecera X-User-* enviada por el cliente.

Pendientes para la siguiente semana (Entrega 7)

- Plan y evidencia de pruebas, checklist de seguridad y registro de defectos corregidos.

- Completar README y procedimiento de despliegue.
- Prueba de carga documentada.

2. Reglas de negocio implementadas

Los valores marcados como parametrizables se configuran con variables de entorno (shared/config.js), así que se pueden cambiar sin tocar el código.

ID	Regla	Servicio	Si se incumple
RN-01	Solo un usuario autenticado puede operar. El token se valida en el Gateway.	Gateway	401 TOKEN_INVALIDO
RN-02	Cada endpoint protegido exige el rol correspondiente (administrador, encargado, docente o alumno).	Gateway y servicios	403
RN-03	Un encargado solo gestiona los laboratorios que tiene asignados; el administrador puede todo.	Inventario y Reservas	403
RN-04	Un recurso no puede tener dos reservas vigentes que se traslapen en horario. Lo garantiza la base de datos.	Reservas	409 RESERVA_TRASLAPADA
RN-05	Límite de reservas vigentes por rol: docente hasta 5, alumno hasta 2.	Reservas	409 / 422
RN-06	Solo se puede reservar un recurso activo (no en mantenimiento ni dado de baja).	Reservas e Inventario	422
RN-07	Un usuario con sanción vigente no puede crear reservas.	Reservas y Usuarios	403 / 422
RN-08	Una reserva se puede cancelar hasta 1 hora antes (parametrizable).	Reservas	409 / 422
RN-09	Si el usuario no se presenta pasada la tolerancia (15 min, parametrizable), la reserva se cancela sola.	Reservas (tarea programada, cada 60 s)	Cancelación automática
RN-10	Solo se entrega un equipo que tenga una reserva vigente; al entregarlo se crea el préstamo.	Reservas	409 / 422
RN-11	Al devolver con daño se crea una incidencia, el recurso pasa a mantenimiento y se sanciona al usuario. Todo se hace en una sola operación; si algo falla se revierte.	Reservas, Inventario y Usuarios	503 SERVICIO_NO_DISPONIBLE
RN-12	Si el préstamo se devuelve tarde, se aplica una sanción automática de 3 días (parametrizable).	Reservas y Usuarios	Sanción automática
RN-13	Se envía recordatorio 60 min antes de la reserva y aviso si un préstamo se pasa de su hora. Si Notificaciones cae, no se bloquea nada.	Notificaciones	Solo advertencia en bitácora
RN-14	Los reportes de uso, ocupación y retrasos son de solo lectura y combinan datos de Reservas e Inventario.	Reportes	403 si el rol no tiene acceso
RN-15	Los datos de entrada se validan con esquemas (Zod) y los errores no revelan detalles internos.	Todos	400 / 422

ID	Regla	Servicio	Si se incumple
RN-16	Se limita el número de peticiones para frenar abusos.	Gateway	429 DEMASIADAS_PETICIONES

3. Flujo completo demostrado

Escenario: un alumno reserva un equipo, el encargado lo entrega, se devuelve dañado y el sistema aplica las consecuencias en todos los servicios.

Paso	Acción	Resultado esperado
1	El alumno inicia sesión (POST /sesiones).	200 con tokenAcceso.
2	Consulta recursos disponibles (Inventario).	200 con listado paginado.
3	Crea una reserva (Reservas valida disponibilidad, límite y estado del recurso).	201; se genera notificación de confirmación.
4	Intenta reservar el mismo horario.	409 RESERVA_TRASLAPADA.
5	El alumno intenta entregar el equipo.	403 (sin permiso).
6	El encargado registra la entrega.	201 con el préstamo creado.
7	El encargado registra la devolución con daño.	200; incidencia creada, recurso en mantenimiento y sanción al usuario.
8	El alumno intenta reservar con sanción vigente.	Rechazo por regla de negocio.
9	El administrador consulta los reportes.	200 con uso, ocupación y retrasos.

Evidencia: colección postman/PrestaLab.postman_collection.json (61 peticiones, 91 verificaciones, con casos positivos y negativos 400, 401, 403, 404, 409 y 422) y 57 pruebas automáticas con npm test.

4. Criterios de aceptación

- Un usuario sin permisos no puede ejecutar operaciones protegidas (RN-01 y RN-02, casos 401 y 403 en Postman).
- La lógica importante no depende del cliente: está en los servicios y en la base de datos.
- Los errores regresan respuestas entendibles con código y mensaje.
- Existe un flujo que conecta Reservas, Inventario, Usuarios y Notificaciones.